LAB 3: Threat Modeling & Risk Assessment (STRIDE / ISO 12100)

Sistem 1: Genel Sürüm — Şişeleme Hattı Tehdit Analizi ve Risk Matrisi

1. STRIDE Yöntemine Göre Tehdit Analizi Matrisi

STRIDE	Hedef Varlık	Saldırı Senaryosu ve Etkisi	Mevcut Risk
Tampering	Normal PLC Modbus/TCP	Dolum süresi parametrelerinin değiştirilerek şişelerin patlatılması.	YÜKSEK (16)
Spoofing	HMI Kontrol Paneli	Saldırganın operatör kimliğine bürünerek durdurma komutlarını iptal etmesi.	ORTA (12)
Repudiation	Saha Otobüsü Logları	Kritik parametre değişikliklerinin kaydedilmeyip inkar edilebilmesi.	DÜŞÜK (6)
DoS	EtherNet/IP Ağ Anahtarı	Ağın veri paketleriyle doldurularak emniyet sinyal iletiminin geciktirilmesi.	YÜKSEK (15)

2. Siber-Fiziksel Risk Değerlendirmesi (ISO 12100 & IEC 62443 Integrasyonu)

Tehlike (Hazard) ve Şiddet (Severity)

Fiziksel Tehlike: Dolum istasyonunda yüksek basınç patlaması ve cam kırılmaları.
Şiddet (S): Ağır yaralanma veya kalıcı uzuv kaybı (S2).

Olasılık (Likelihood) ve Önleme

Ağ Sızılabilirliği: Korumasız Modbus/TCP protokolü nedeniyle yüksek ($O=4$).
Kaçınma İmkanı: Ani patlamada kaçınma imkanı yok ($AV=2$).

3. Şişeleme Hattı Saldırı Ağacı (Attack Tree) Görseli



LAB 3: Threat Modeling & Risk Assessment (STRIDE / ISO 12100)

Sistem 2: Özel Sürüm — PaketPro 3000 Kritik Tehdit ve Savunma Tedbirleri

1. PaketPro 3000 STRIDE & Siber-Fiziksel Tehdit Haritası

STRIDE Vektörü	Saldırı Hedefi	Siber Müdahale & Fiziksel Sonuç	Öncesi / Sonrası Risk
Elevation of Privilege	Uzak Bakım Modülü	Admin yetkisi alarak Safety PLC Muting fonksiyonunu aktifleştirme. Bıçak durmaz.	YÜKSEK (20) → DÜŞÜK (4)
Tampering	Isıtıcı Çene PID	Sıcaklık set değerini 300°C'ye çıkararak termal yangın ve zehirli gaz salınımı.	YÜKSEK (18) → DÜŞÜK (3)
Information Disc.	HMI Trafiği (HTTP)	Ağ dinlenerek yetkili operatör parolarının ele geçirilmesi.	ORTA (10) → DÜŞÜK (2)

2. Derinlemesine Savunma (Defense-in-Depth) ve Hafifletme (Mitigation)

1. Donanımsal Emniyet Kilidi

Yazılımsal Muting komutu gelse dahi fiziksel kilit anahtarı (Key-switch) pozisyonda değilse emniyet fonksiyonu devre dışı bırakılamaz.

2. Bağımsız Termal Sigorta

PLC yazılımından bağımsız mekanik termostat bimetal şalteri, çene sıcaklığı 180°C'yi geçtiğinde gücü donanımsal olarak keser.

3. PaketPro 3000 Risk Düşürme (Mitigation) Akış Şeması

